



Raport ekspercki

Badanie bezpieczeństwa sieci od środka

5

Wykryte urządzenia

10

Otwarte porty

14

Ustalenia wymagające działania

5

Luki w pokryciu badania

Sonda

Sonda demonstracyjna

Identyfikator badania

PROBKA-0000-0000-0000-DEMO

Data wykonania badania

2026-09-18 09:12:44

Przebieg badania

zakończone

Adres sondy w badanej sieci

192.0.2.250

Raport odebrany

2026-10-04 14:50:33 UTC

1. Podsumowanie badania

Ocena ryzyka wynikająca z całości badania.

Badanie wykazało stan krytyczny. Na jednym z hostów potwierdzono zdalne wykonanie kodu na bazie danych, a sonda zrealizowała polecenie systemowe przez usługę bazy — to nie jest przesłanka teoretyczna, lecz potwierdzony wektor pełnej kompromitacji. Ten sam host łączy go z podatnością SSL POODLE oraz z kontem bazy bez hasła i danymi wrażliwymi (PESEL, dane kart) dostępnymi w bazie. Sieć wymaga natychmiastowych działań naprawczych, a priorytetem jest odcięcie eksponowanej bazy od ruchu sieciowego.

Poza dwoma ustaleniami krytycznymi odnotowano pięć o wadze wysokiej i siedem o wadze średniej, w tym Telnet przesyłający hasła otwartym tekstem oraz brak blokady Gratuitous ARP umożliwiający przechwycenie ruchu. Łącznie zidentyfikowano 14 ustaleń wymagających działania. Część obszarów nie została zbadana — między innymi skanowanie hosta 192.0.2.40, sieci bezprzewodowe oraz wycieki z katalogu LDAP — więc obraz ryzyka jest niepełny i nie wolno przyjmować, że obszary nieprzebadane są bezpieczne.

2. Ustalenia według wagi

Wszystko, co badanie wykazało, zebrane w jednym miejscu i uszeregowane od najpoważniejszego. Wagi wynikają z tego, co stwierdziły testy - ustalenie, którego test nie zdołał potwierdzić, jest oceniane niżej niż potwierdzone.

2

Krytyczne

5

Wysokie

7

Średnie

0

Informacyjne

WAGA	GDZIE	USTALENIE
Krytyczne	192.0.2.30 ssl-poodle · port 8443	SSL POODLE information leak CVE-2014-3566
Krytyczne	192.0.2.30	Potwierdzone zdalne wykonanie kodu na bazie danych (RCE) Sonda wykonała polecenie systemowe przez usługę bazy danych.
Wysokie	192.0.2.30 http-slowloris-check · port 8443	Slowloris DOS attack CVE-2007-6750
Wysokie	192.0.2.30	Konto bazy danych bez hasła root
Wysokie	192.0.2.30	Dane wrażliwe dostępne w bazie danych PESEL w crm.klienci; KARTA KREDYTOWA w crm.platnosci
Wysokie	192.0.2.20 23/TCP	Telnet dostępny w sieci Protokół przesyła hasła otwartym tekstem.
Wysokie	cała sieć	Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.
Średnie	192.0.2.30	Serwer WWW ujawnił ścieżki wymagające weryfikacji Wykryte podczas fuzzingu katalogów; część może być fałszywa - wymaga ręcznego potwierdzenia. https://192.0.2.30:8443/.git/config , https://192.0.2.30:8443/backup.sql , https://192.0.2.30:8443/phpinfo.php
Średnie	192.0.2.20 port 80	Panel kamery dostępny po nieszyfrowanym HTTP Wymuś HTTPS i ogranicz dostęp do sieci zarządzającej.
Średnie	192.0.2.1 port 53	Znane podatności w dnsmasq 2.80 (3 CVE, najwyższy CVSS 8.1) CVE-2021-3448, CVE-2020-25681, CVE-2020-25684 Dopasowanie po numerze wersji - wymaga potwierdzenia, czy podatny kod jest faktycznie używany.
Średnie	192.0.2.10 445/TCP	Udostępnianie plików SMB dostępny w sieci Dostęp do plików i klasyczny cel ataków w sieci lokalnej.
Średnie	192.0.2.30 3306/TCP	Baza danych MySQL dostępny w sieci Baza danych nasłuchująca w sieci.

WAGA	GDZIE	USTALENIE
Średnie	192.0.2.30 502/TCP	Modbus dostępny w sieci
Średnie	cała sieć	Porty przepuszczane na zewnątrz: 23, 445, 3389

Luki w pokryciu badania (5)

Poniższe testy nie dostarczyły wyniku. Tych obszarów badanie nie sprawdziło, więc nie można ich uznać ani za bezpieczne, ani za zagrożone.

- 192.0.2.40 — Skanowanie portów: test nie powiódł się na tym urządzeniu
- Sieci bezprzewodowe: test zablokowany przez zakres lub politykę badania
- Zatrutowanie rozgłoszeń — sonda nie przekazała wyniku
- Wycieki z katalogu LDAP — test nie wykonał się
- Bezpieczeństwo sieci bezprzewodowej — Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.

Ustaleniem o najwyższej wadze jest potwierdzone zdalne wykonanie kodu na bazie danych na 192.0.2.30 — sonda wykonała polecenie systemowe przez usługę bazy, co oznacza, że atakujący może przejąć kontrolę nad hostem bez uwierzytelnienia aplikacyjnego. Drugie ustalenie krytyczne to SSL POODLE (CVE-2014-3566) na porcie 8443 tego samego hosta; mechanizm polega na wykorzystaniu słabości dopełnienia w SSL 3.0 do odszyfrowania ruchu i wyprowadzenia danych w scenariuszu pośrednika.

Wśród ustaleń wysokich wykryto Slowloris (CVE-2007-6750) na porcie 8443 — wyczerpywanie puli połączeń przez powolne nagłówki, prowadzące do odmowy usługi. Konto bazy bez hasła (root) oraz dane wrażliwe (PESEL, KARTA KREDYTOWA) w tabelach crm.klienci i crm.platnosc na 192.0.2.30 stanowią bezpośrednie ryzyko naruszenia danych osobowych i finansowych. Na 192.0.2.20 port 23/TCP udostępnia Telnet, który przesyła hasła otwartym tekstem. Brak blokady Gratuitous ARP pozwala przekierować ruch w segmencie i podsłuchać go w wariancie MITM. Ustalenia średnie obejmują ujawnione ścieżki serwera WWW, panel kamery po HTTP, znane podatności dnsmasq oraz wystawione usługi SMB, MySQL i Modbus. Luki w pokryciu badania — nieudany skan 192.0.2.40, zablokowane testy sieci bezprzewodowej, brak wyniku zatrutowania rozgłoszeń oraz niewykonany test wycieków z LDAP — pozostają niezbadane.

3. Wykryte urządzenia

Przegląd segmentu sieci i lista wszystkich urządzeń, które się w nim odezwały. Urządzenie, które odpowiedziało przy wykrywaniu, ale zamilkło przy skanowaniu portów, jest odnotowane osobno.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

ADRES	ADRES SPRZĘTOWY	PRODUCENT I MODEL	STAN
192.0.2.1	02:00:5e:00:53:01	Acme Networks GW-200 Linux 4.x (router)	3 otwarte porty
192.0.2.10	02:00:5e:00:53:0a	NorthStore NAS-4B Linux (NAS)	2 otwarte porty
192.0.2.20	02:00:5e:00:53:14	Visinet IP-Cam 3 Embedded Linux	2 otwarte porty
192.0.2.30	02:00:5e:00:53:1e	Generic Server Co. CentOS 7	3 otwarte porty
192.0.2.40	—	nieznany	skanowanie nieudane test przekroczył limit czasu

Wykrytych urządzeń: 5, odpowiedziało na skanowanie portów: 4.

W sieci wykryto pięć urządzeń, z których cztery odpowiedziały na skanowanie portów i na każdym z tych czterech stwierdzono co najmniej jeden otwarty port. Zidentyfikowano router Acme Networks GW-200 (192.0.2.1), urządzenie NAS NorthStore NAS-4B (192.0.2.10), kamerę Visinet IP-Cam 3 (192.0.2.20) oraz serwer CentOS 7 (192.0.2.30). Skanowanie piątego urządzenia, 192.0.2.40, nie powiodło się — test przekroczył limit czasu — dlatego dla tego adresu nie jest dostępny ani profil usług, ani ocena stanu.

4. Usługi dostępne w sieci

Sprawdzenie, co nasłuchuje na każdym wykrytym urządzeniu i w jakiej wersji. Wynik zostaje zachowany w pełnej postaci, nie w formie skrótu.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

URZĄDZENIE	PORT	USŁUGA	WERSJA ROZPOZNANA PRZEZ SONDĘ
192.0.2.1	53/TCP	domain	dnsmasq 2.80
192.0.2.1	80/TCP	http	lighttpd 1.4.59
192.0.2.1	443/TCP	https	lighttpd 1.4.59
192.0.2.10	445/TCP	microsoft-ds	Samba smbd 4.15.13
192.0.2.10	5000/TCP	http	Synology DSM httpd
192.0.2.20	23/TCP	telnet	nie ustalono
192.0.2.20	554/TCP	rtsp	nie ustalono
192.0.2.30	22/TCP	ssh	OpenSSH 7.4
192.0.2.30	3306/TCP	mysql	MySQL 5.7.38
192.0.2.30	8443/TCP	https	nie ustalono

Otwartych portów łącznie: 10, na 4 urządzeniach.

Na 192.0.2.1 wystawiono usługi DNS (dnsmasq 2.80) oraz HTTP i HTTPS (lighttpd 1.4.59). Na 192.0.2.10 udostępniono SMB (Samba smbd 4.15.13) oraz interfejs DSM na porcie 5000. Na 192.0.2.20 działa Telnet i RTSP, a na 192.0.2.30 — SSH, MySQL i HTTPS na porcie 8443. Ryzyko wynika przede wszystkim z faktu nasłuchiwanie usług zarządzających i bazodanowych w sieci oraz z niewierzytelnych kanałów: Telnet przekazuje poświadczenia jawnym tekstem, a panel kamery dostępny jest po HTTP.

5. Pogłębione testy podatności

Testy uruchamiane przeciwko znalezionym usługom. Ustalenie oznaczone jako wymagające uwagi to takie, które nie zakończyło się zwykłym „nic nie znaleziono”.

URZĄDZENIE	TEST	USTALENIE
192.0.2.30	ssl-poodle	VULNERABLE: SSL POODLE information leak State: VULNERABLE IDs: CVE:CVE-2014-3566
192.0.2.30	http-slowloris-check	VULNERABLE: Slowloris DOS attack State: LIKELY VULNERABLE IDs: CVE:CVE-2007-6750

Ustaień łącznie: **3**, w tym wymagających uwagi: **2**, pozostałe 1 zakończyło się wynikiem czystym.

W ramach pogłębionych testów uruchomionych przeciwko znalezionym usługom potwierdzono podatność na SSL POODLE (stan VULNERABLE, CVE-2014-3566) na 192.0.2.30:8443 w skrypcie ssl-poodle. Test http-slowloris-check na tym samym porcie zwrócił wynik LIKELY VULNERABLE dla ataku Slowloris (CVE-2007-6750). Pozostały jeden test zakończył się wynikiem czystym. Trzy ustalenia pochodzą z pogłębionych testów, z czego dwa wymagają uwagi.

6. Ekspozycja i poświadczenia

Udziały plików dostępne bez uwierzytelnienia, ruch przestarzałych mechanizmów rozwiązywania nazw, pozostawione domyślne dane logowania oraz informacje wyciekające z katalogu firmowego do klientów anonimowych.

BADANY OBSZAR	WYNIK
Anonimowe sesje i udziały SMB	stan prawidłowy — nie stwierdzono podatności
Zatrutowanie rozgłoszeń	brak danych Sonda nie przekazała wyniku tego testu.
Skanowanie szablonami znanych podatności	stan prawidłowy — nie stwierdzono podatności
Domyślne poświadczenia	stan prawidłowy — nie stwierdzono podatności
Wycieki z katalogu LDAP	test nie wykonał się Test nie został uruchomiony, więc ten obszar pozostaje niesprawdzony.
Ryzyka infrastrukturalne	stan prawidłowy — nie stwierdzono podatności

Jeden moduł badania nie wykonał się poprawnie. Wyniku tych testów nie należy czytać jako „nic nie znaleziono” - one się nie odbyły.

Anonimowe sesje i udziały SMB nie wykazały podatności. Skanowanie szablonami znanych podatności oraz kontrola domyślnych poświadczeń zakończyły się wynikiem czystym — stan prawidłowy. Ryzyka infrastrukturalne nie ujawniły podatności. Test wycieków z katalogu LDAP nie wykonał się, a wynik zatrutowania rozgłoszeń nie został przekazany przez sondę; dla tych dwóch obszarów nie odnotowano wyniku, więc nie są one potwierdzone jako bezpieczne.

7. Protokoły przemysłowe ICS i OT

Punkty końcowe sterowania przemysłowego, takie jak CODESYS Runtime, EtherNet/IP czy IEC 60870-5-104, które zwykle nie mają czego szukać w sieci biurowej.

URZĄDZENIE	PORT	PROTOKÓŁ	STAN	OCENA SONDY
192.0.2.30	502/TCP	Modbus	open	WARNING

Punktów końcowych ICS/OT: 1. Stan open|filtered oznacza, że sonda nie mogła rozstrzygnąć, czy port jest otwarty, czy odfiltrowany.

Wykryto jeden punkt końcowy protokołów przemysłowych: Modbus na 192.0.2.30, port 502/TCP, w stanie open, z oceną sondy WARNING. Host ten jest jednocześnie serwerem ogólnym z wystawioną bazą danych i usługami WWW. Utrzymywanie surowego protokołu Modbus bez segmentacji w tej samej sieci co usługi korporacyjne oznacza brak izolacji strefy OT.

8. Diagnostyka sieci

Kondycja i konfiguracja sieci: opóźnienia, DNS, podatności na podsłuch i podszywanie się, zabezpieczenie portu dostępowego, ruch wychodzący oraz przepustowość. Poniżej znajdują się wyłącznie te testy, których wynik sonda przekazała.

Opóźnienia w sieci

Status	ok
Najniższe	0.4 ms
Średnie	0.8 ms
Najwyższe	1.9 ms

Kondycja DNS

Status	ok
Odpytany serwer	192.0.2.1
Czas odpowiedzi	12 ms

Podatność na podsłuch (MITM)

Status	ok
▲ Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.	
Assessment	Przełącznik nie blokuje Gratuitous ARP - ruch w segmencie można przekierować.

Filtrowanie ruchu wychodzącego

Status	ok
Porty przepuszczane na zewnątrz	▲ 23, 445, 3389

Bezpieczeństwo sieci bezprzewodowej

Status	blocked
Reason	foreign_block
▲ Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.	
Przechwycone ramki EAPOL	0

Przepustowość łącza

Opóźnienie (ping)	18.4 ms
Pobieranie	184.2 Mbit/s
Wysyłanie	41.7 Mbit/s

Najbardziej obciążające urządzenia

ADRES	PAKIETY	RUCH ŁĄCZNIE	WYSŁANE	ODEBRANE
192.0.2.10	182340	136,3 MB	90000 pk · 76,3 MB	92340 pk · 60,0 MB
192.0.2.1	90120	17,5 MB	45000 pk · 8,6 MB	45120 pk · 9,0 MB

Opóźnienia w sieci są niskie (najwyższe 1,9 ms), a kondycja DNS na serwerze 192.0.2.1 nie budzi zastrzeżeń — czas odpowiedzi wyniósł 12 ms. Stwierdzono jednak brak blokady Gratuitous ARP: przełącznik nie blokuje tych rozgłoszeń, więc ruch w segmencie można przekierować i podsłuchać. Filtrowanie ruchu wychodzącego przepuszcza na zewnątrz porty 23, 445 i 3389. Test bezpieczeństwa sieci bezprzewodowej nie odbył się — nie udało się włączyć trybu monitora, a liczba przechwyconych ramek EAPOL wyniosła 0. Największe obciążenie generowały 192.0.2.10 (182340 pakietów, 136,3 MB) oraz 192.0.2.1 (90120 pakietów, 17,5 MB).

9. Plan naprawy

Działania wynikające wyłącznie z ustaleń tego badania, uszeregowane od najpilniejszego.

1. Odcięcie dostępu sieciowego do bazy danych na 192.0.2.30 (3306/TCP) — priorytet najwyższy, z uwagi na potwierdzone zdalne wykonanie kodu.
2. Nadanie hasła konta root bazy danych na 192.0.2.30 i ograniczenie jego uprawnień.
3. Ograniczenie dostępu do danych wrażliwych (PESEL, KARTA KREDYTOWA) w bazie na 192.0.2.30 oraz weryfikacja zakresu ich ekspozycji.
4. Wyłączenie protokołu SSLv3 na 192.0.2.30:8443 w celu usunięcia podatności SSL POODLE.
5. Wdrożenie ochrony przed atakiem Slowloris na 192.0.2.30:8443.
6. Wyłączenie usługi Telnet na 192.0.2.20 i zastąpienie jej kanałem szyfrowanym.
7. Włączenie mechanizmu blokady Gratuitous ARP (dynamic ARP inspection) w segmencie.
8. Ograniczenie filtrowania ruchu wychodzącego na portach 23, 445 i 3389.
9. Aktualizacja dnsmasq 2.80 na 192.0.2.1 w związku z trzema znanymi podatnościami.
10. Ograniczenie dostępu do usługi SMB na 192.0.2.10 do niezbędnych hostów.
11. Wymuszenie HTTPS na panelu kamery 192.0.2.20 i ograniczenie dostępu do sieci zarządzającej.
12. Weryfikacja ujawnionych ścieżek na 192.0.2.30:8443 (.git/config, backup.sql, phpinfo.php) i usunięcie potwierdzonych ekspozycji.
13. Wdrożenie izolacji segmentu OT z punktem końcowym Modbus na 192.0.2.30.
14. Powtórzenie skanowania portów na 192.0.2.40, które zakończyło się przekroczeniem limitu czasu.
15. Wykonanie testu wycieków z katalogu LDAP.

Ponowne przeprowadzenie audytu weryfikującego przy pomocy sprzętowego analizatora w celu technicznego potwierdzenia skuteczności wdrożonych zabezpieczeń.